PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Menaces cyber : secteurs de la santé et de l'eau

03-1130 CERT-FR - État de la menace sur les secteurs de la santé et de l'eau — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La part des incidents de santé traités par l'ANSSI est passée de 2,87 % en 2020 à 11,4 % en 2023.
2. Dans le secteur de l'eau, la menace cybercriminelle est marquée par 8 rançongiciels sur 28 compromissions entre janvier 2021 et août 2024.
3. Le Cyber Resilience Act est un règlement européen dont l'application pleine est prévue pour le 11 décembre 2027.

État de la menace : secteur de la santé

Notion	À retenir
Secteur critique	Risques sur **disponibilité, intégrité, confidentialité, traçabilité** pouvant mettre en danger la **vie humaine**. Part ANSSI : **2,87 %** (2020) à **11,4 %** (2023).
Menace lucrative	**30** compromissions par rançongiciel (2022-2023), soit **10 %**. **CH Sud Francilien** (août 2022) : **11 Go** divulgués, **7 M€**. Février 2024 : fuite **Viamedis/Almerys**, **> 33 millions** de personnes.
Espionnage/Déstabilisation	Cibles : recherches **vaccins/traitements** (étatiques : **Russie, Chine, Iran, Corée du Nord**). DDoS (**Anonymous Sudan**, juin 2023) et groupes **pro-russes** (août 2024).
Recommandations	Approche globale (**actifs, état, menaces, risques, mesures**). **RSSI** dans tous les projets ; cybersécurité, informatique et **biomédical** ensemble. D'abord **état des lieux, sensibilisation, résilience**. Programme **CaRE** : **2023-2027**.

État de la menace : secteur de l'eau

Notion	À retenir
Secteur exposé	Entre **janvier 2021** et **août 2024**, **46 entités** ont subi un événement (dont **12 opérateurs régulés**). Menace cybercriminelle majeure : **8 rançongiciels** sur **28 compromissions**.
Infrastructures vulnérables	Surface d'attaque élargie par les **installations anciennes**, **sites dispersés**, **faibles budgets**, **télégestion** et **industrie 4.0**. Protocoles **Modbus** ou **S7Comm** sans chiffrement/authentification et **IHM** exposées sur Internet.
Déstabilisation, espionnage et sabotage	Risques accrus par les **JO Paris 2024**. Groupes : **Cyber Army of Russia Reborn** (contrôle d'IHM), **Cyber Av3ngers** (automates **Unitronics**) et **Volt Typhoon** (prépositionnement infrastructures américaines).
Recommandations	Intégrer la sécurité dans les **contrats de délégation de service public** (clauses opposables). Analyser l'**accès physique**, la **porosité IT/OT** et l'**administration**. Utiliser **OPC-UA**, **IPsec** ou **TLS** ; ne jamais exposer le **SCADA** sur Internet.

Vulnérabilités des produits de santé (REX 2026)

Notion	À retenir
Le constat	Sondage ANS : **82 %** des établissements ont eu connaissance de vulnérabilités (12 derniers mois). CERT Santé : incidents malveillants **+22 %** (**328** en 2024 → **400** en 2025).
Correctifs trop lents	Traitement > **1 an** chez 4 éditeurs ; un correctif planifié **5 ans** après signalement. Correctifs noyés dans des **évolutions fonctionnelles payantes** ; délais allongés par le marquage **CE**. Un **WAF** ne remplace jamais la correction.
Gestion des secrets	Mot de passe serveur lisible via une adresse dans le navigateur, répertoire `.git` accessible, identifiants admin dans le code, identifiants de **télémaintenance par défaut**.
Injections de code	Failles **XSS** et **SQLi**. Toute donnée (champ, en-tête `HTTP`, paramètre d'URL) doit être contrôlée. Proscrire les développements internes d'authentification.
Accès distants	Instances exposées sans authentification (ex: accès **VNC**). Recommandation : authentification robuste/native, puis **MFA** ou **VPN**.
Contrôle d'accès	Accès non conformes au **moindre privilège** (ex: patient consultant données d'autres patients). Risque de compromission par hameçonnage.
Cadre réglementaire	Règlement européen **2024/2847** (**Cyber Resilience Act**). Application pleine le **11 décembre 2027** (hors dispositifs médicaux).

Données clés et sanctions

90 %
Établissements sans canal formalisé pour remonter les vulnérabilités
Sondage Agence du numérique en santé

74 %
Établissements confrontés à des éditeurs tardant ou refusant de corriger
Sondage Agence du numérique en santé

15 millions d'euros
Amende maximale possible par l'ANFR
Cyber Resilience Act

2,5 %
Amende maximale (chiffre d'affaires annuel mondial)
Cyber Resilience Act

Pièges et confusions

- ⚠ Confondre l'usage d'un WAF avec la correction définitive d'une application.
- ⚠ Croire qu'un correctif de sécurité doit attendre une évolution fonctionnelle payante.
- ⚠ Penser qu'une IHM non sécurisée nécessite des attaquants très compétents pour causer des dégâts.
- ⚠ Confondre l'informatique de gestion (IT) avec la technologie opérationnelle (OT).
- ⚠ Oublier que la fuite Viamedis et Almerys concerne près de la moitié de la population française.

Sigles et définitions

DPI	Le dossier patient informatisé regroupe sous forme numérique les informations médicales d'un patient.
Plan blanc	Plan de gestion de crise des établissements de santé intégrant un volet cyber depuis 2023.
CERT-Santé	Structure créée en 2017 assurant le suivi sectoriel des incidents de santé.
OT	Technologie opérationnelle désignant les systèmes qui pilotent des processus physiques.
IHM	Interface homme-machine permettant de superviser et de commander un équipement industriel.
CRA	Cyber Resilience Act, règlement européen 2024/2847 fixant les exigences de cybersécurité des produits numériques.
DSP	Délégation de service public confiant l'exploitation d'un service d'eau à un tiers.

Auto-test

1. Quelle est la part des établissements n'ayant aucun canal formalisé pour signaler une vulnérabilité à leur éditeur ?
2. Quelle est l'amende maximale possible par l'ANFR au titre du CRA ?
3. Quel principe limite chaque utilisateur aux seules actions et données légitimes ?
4. Quelle technologie permet de piloter à distance des infrastructures réparties sur le territoire ?
5. Quelle est la période couverte par le programme CaRE ?

Réponses : **1.** 90 % · **2.** 15 millions d'euros · **3.** Le principe de moindre privilège · **4.** La télégestion · **5.** 2023-2027

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.